

NL to Safe SQL Execution Pipeline

Design Document & Cover Letter

Alexander Korbuto | github.com/AlexKorbuto | June 2026

1. Problem Statement

Operational SaaS products often need a natural-language query interface so staff can explore inbox-style data without writing SQL. The naive approach - asking an LLM to emit SQL and executing it - creates severe risks: SQL injection, unbounded data access, non-deterministic queries, and schema hallucination.

The required pipeline: users ask in plain language, but the LLM never produces executable SQL. It emits constrained Query Intent JSON that a deterministic transpiler turns into parameterized SQL against SQLite.

Goals

- Safety by design - SQL injection structurally impossible; invalid intents fail closed
- Determinism - same intent JSON always produces the same SQL
- Testability - builder, validator, and pipeline testable without the LLM
- Operability - HTTP API, seed data, audit trail, debug visibility
- TypeScript - full implementation in TypeScript

2. Solution Options Considered

All candidates assume an LLM in the NL understanding step. The decision was how the model participates, not whether to use one.

Option A - LLM generates SQL + post-execution sandbox

Rejected. Parsing SQL reliably is hard; bypasses are common. Violates the core constraint.

Option B - LLM generates Query Intent JSON + deterministic builder (CHOSEN)

NL -> LLM -> Query Intent JSON -> Validator -> Query Builder -> SQLite. Separates probabilistic NL understanding from deterministic execution.

3. Chosen Architecture

Pipeline: Web UI / curl -> POST /query (Fastify) -> LlmService (OpenAI JSON) -> IntentValidator (Zod + whitelist) -> QueryBuilder (SELECT/JOIN/WHERE/ORDER BY/LIMIT) -> DatabaseExecutor (prepared statements) -> ResponseFormatter.

Security layers

- Prompt contract - system prompt forbids SQL; response_format: json_object
- Zod schema - type: select only; known targets and operators
- Schema registry whitelist - allowed tables, fields, ops per field type
- Deterministic builder - only ? placeholders, no user value concatenation
- Fail-closed errors - validation -> HTTP 400; LLM failure -> HTTP 502

Data model

Generic inbox schema to exercise the pipeline (15 conversations, 28 messages, 10 tags). The transpiler is domain-agnostic - only the registry and seed data are swappable.

Entity	Key fields	Purpose
conversations	id, title, status, created_at	Thread metadata; open/closed
messages	id, conversation_id, role, content	role: user or assistant
tags	id, name	Label catalog
conversation_tags	conversation_id, tag_id	Many-to-many link

4. Validation Approach

Layer	Validation
Date resolver	Unit tests: -7 days, today, this month, ISO
Intent validator	Unit tests: forbidden tables/fields/ops/limits
Query builder	Unit tests: JOIN, WHERE, ORDER BY, LIMIT
Pipeline	Integration test with mock LLM
Data layer	npm run db:verify - 4 canned intents
Manual E2E	Web UI + TEST_QUERIES.md catalog

5. Expected Query Behavior

Seed reference date: 2026-06-03. Relative expressions (-7 days, today) resolve against the server clock at runtime.

5.1 Conversation filters

Query	Expected result
Show open conversations	9 rows - all status = open
List closed conversations	6 rows - all status = closed
Show conversation id 7	1 row - API rate limit question
Conversations with title containing billing	1 row - id 1
Show all conversations ordered by created_at descending	15 rows - newest first (id 13)

5.2 Message search

Query	Expected result
Find messages containing refund	3 rows - conv 2 (x2) and conv 6
Messages from user role only	15 rows - role = user
Messages from assistant	13 rows - role = assistant
Messages in conversation 7	2 rows - API thread
Find messages containing password	2 rows - conv 8 and 11

5.3 Tag filters

Query	Expected result
Conversations tagged billing	4 rows - ids 1, 2, 5, 6
Conversations tagged security	2 rows - ids 8, 11
Conversations tagged bug	2 rows - ids 12, 13
Conversations tagged refund	2 rows - ids 2, 5
Conversations tagged mobile	1 row - id 13

5.4 Date filters

Query	Expected result
Show conversations from the last 7 days	5 rows - ids 1, 5, 8, 12, 13
Conversations created after 2026-05-25	5 rows - ids 1, 5, 8, 12, 13
Closed conversations created before 2026-06-01	6 rows - all closed
Conversations created before 2026-03-01	2 rows - ids 14, 15
Messages from the last 30 days	26 rows - all except conv 14-15

5.5 Combined filters

Query	Expected result
-------	-----------------

Open conversations tagged billing	2 rows - ids 1, 5
Open conversations tagged bug	2 rows - ids 12, 13
Closed conversations tagged refund	1 row - id 2
Messages about API rate limits	2 rows - conversation 7
Open conversations from the last 7 days	3 rows - ids 5, 8, 13

6. Conclusion

This project demonstrates a safe NL-to-data pipeline: the LLM is confined to a structured intent layer, and all executable SQL is produced deterministically with whitelists and prepared statements.

The seed dataset and example queries validate core patterns - status filters, text search, tag joins, relative dates, and multi-condition queries - without coupling the architecture to any single business domain.